

Sviluppo Traccia recupero crediti

Introduzione al Contesto Operativo e Finalità del Progetto Architettuale (Parte Introduttiva)

L'evoluzione delle architetture informatiche all'interno di scenari aziendali complessi richiede un'attenta analisi sistemistica capace di bilanciare le **esigenze di connettività, la scalabilità dell'infrastruttura e le imprescindibili necessità di sicurezza dei dati**.

Il contesto in esame riguarda un'azienda operante nel settore del recupero crediti, e si trova ad affrontare una profonda trasformazione logistica e operativa.

Tale trasformazione è innescata dall'acquisizione di un nuovo edificio adiacente alla sede storica, un evento che funge da catalizzatore per un ridisegno completo della topologia di rete aziendale.

La rete informatica, fino a questo momento confinata in una singola struttura, deve ora espandersi per coprire un ambiente multi-edificio, garantendo al contempo una netta segregazione dei flussi informativi e l'integrazione di moderni paradigmi di lavoro come il Bring Your Own Device (BYOD).

Il presente documento analizza in modo esaustivo le criticità dell'infrastruttura di partenza e sviluppa una progettazione ingegneristica completa per il nuovo ecosistema di rete. Attraverso l'applicazione rigorosa degli standard internazionali di cablaggio strutturato, delle tecnologie di switching di livello 2, del routing avanzato di livello 3 e di stringenti policy di sicurezza firewall e Access Control List (ACL), si delinea un'architettura in grado di sostenere il carico operativo di centinaia di host distribuiti, garantendo tolleranza ai guasti e protezione da intrusioni interne ed esterne.

Analisi Architettuale e Limitazioni dello Scenario Iniziale (Analisi dello scenario di partenza)

La progettazione di una nuova rete non può prescindere dalla comprensione profonda delle vulnerabilità insite nello scenario di partenza. **L'infrastruttura originale** dell'azienda era radicata in una singola sede operativa, **caratterizzata da un'architettura logica di tipo non gerarchizzato** (flat network) o, nella migliore delle ipotesi, **insufficientemente segmentata**.

All'interno di questa struttura convivevano tre macro-aree funzionali: un settore operativo dedicato alla gestione dei reclami, composto da trentadue postazioni host; un settore dedicato specificamente al recupero crediti, equipaggiato con sedici postazioni; e un polo amministrativo che fungeva da fulcro per le risorse condivise.

Tra queste risorse spiccavano un server FTP, essenziale per l'immagazzinamento centralizzato e il recupero delle pratiche documentali relative sia ai reclami che ai recuperi, e una **stampante di rete condivisa in modo indiscriminato da tutti i settori operativi**, la quale risiedeva fisicamente e logicamente **nel dominio dell'amministrazione**.

Dal punto di vista dell'ingegneria delle reti, un'architettura in cui decine di host, **server e stampanti risiedono nel medesimo dominio di broadcast rappresenta un rischio sistemico considerevole**. In un dominio di broadcast unificato, ogni pacchetto destinato

all'indirizzo fisico FF:FF:FF:FF:FF:FF (come le richieste del protocollo ARP o i messaggi di discovery DHCP) viene propagato a tutte le porte degli switch attivi, obbligando l'interfaccia di rete di ciascun computer collegato a elaborare il frame per determinare se ne sia il reale destinatario.

Sebbene la traccia operativa asserisca che i settori aziendali "non comunicano tra loro", in un'architettura di **rete non segmentata tale affermazione rappresenta più una direttiva aziendale teorica che un blocco tecnico reale. In assenza di separazione logica** ai livelli inferiori della pila ISO/OSI, **un utente malevolo** o un software compromesso all'interno del settore reclami **potrebbe facilmente intercettare il traffico destinato al server FTP o effettuare attacchi di tipo ARP poisoning per deviare i pacchetti** del settore recupero crediti, compromettendo la confidenzialità di dati finanziari estremamente sensibili.

Inoltre, l'infrastruttura iniziale si basava su router e switch dalle capacità limitate. L'utilizzo di **switch privi di configurazioni VLAN native** espone l'azienda a **colli di bottiglia** qualora il traffico dovesse subire impennate improvvise. La migrazione verso una topologia multi-edificio, unita all'inserimento di nuovi dipartimenti e di centinaia di nuovi terminali informatici, rende il mantenimento dello schema logico iniziale non solo inefficiente, ma tecnologicamente insostenibile. **Si rende perciò mandatoria l'implementazione di un modello gerarchico strutturato in tre livelli: Core, Distribution e Access.**

Ingegnerizzazione del Cablaggio Strutturato Multi-Edificio (Progettazione architettura fisica)

Il fondamento fisico su cui si erge l'affidabilità dell'intera architettura logica è il sistema di cablaggio strutturato. La nuova sede acquisita, che si sviluppa su quattro livelli, richiede una progettazione ex novo dell'infrastruttura fisica nel pieno rispetto delle normative internazionali, quali la ISO/IEC 11801 a livello globale, la EN 50173 a livello europeo e le specifiche ANSI/TIA-568 in ambito statunitense, le quali standardizzano le topologie e i mezzi trasmissivi per le reti telematiche commerciali.

La Dorsale di Comprensorio (Campus Backbone)

Il collegamento tra il vecchio stabile, che manterrà in funzione i due settori storici, e il nuovo edificio, destinato ad accogliere la dirigenza e i nuovi poli operativi, costituisce il Campus Backbone. L'interconnessione tra edifici distinti pone sfide ingegneristiche complesse legate non solo alla distanza, ma soprattutto alla sicurezza elettrica. **L'utilizzo di cavi in rame a doppino intrecciato (UTP o STP) per i collegamenti esterni è fortemente sconsigliato** e, in molte giurisdizioni, vietato dalle normative di sicurezza oltre che inaffidabili dal punto di vista elettrico.

Per **superare queste limitazioni, il progetto prevede la stesura di un cavo in fibra ottica** per il Campus Backbone. La fibra ottica, essendo realizzata in vetro di silice o polimeri plastici, è un dielettrico perfetto e garantisce il totale isolamento galvanico tra le due strutture. Oltre ai benefici in termini di sicurezza elettrica, la trasmissione basata su fotoni **offre un'immunità assoluta alle interferenze elettromagnetiche (EMI) e alle radiofrequenze (RFI)**, impedendo qualsiasi tentativo di intercettazione passiva del segnale lungo il perimetro esterno. A seconda della distanza fisica tra i due Main Equipment Room (MER) degli edifici, si opterà per una fibra ottica multimodale capace di supportare link a 10 Gigabit Ethernet o 40 Gigabit Ethernet su distanze fino a 400 metri o monomodale per distanze chilometriche e larghezze di banda

teoricamente illimitate grazie all'assenza di dispersione modale.

Produrre la schematizzazione grafica

Cablaggio di Edificio (Building Backbone) e Cablaggio Orizzontale

All'interno del **nuovo stabile a quattro livelli**, il **centro nevralgico della rete** sarà ospitato in un locale tecnico dedicato, preferibilmente situato **al piano terra o in un'area dotata di accessi controllati**, sistemi di raffreddamento di precisione (HVAC) e gruppi di continuità (UPS). Questo locale **fungerà da Centro Stella di Edificio (Building Distributor)**. **Da qui**, cavedi tecnici verticali permetteranno la posa del Building Backbone, anch'esso preferibilmente in fibra ottica multimodale o in rame di altissima categoria, per interconnettere il rack principale **con gli armadi di piano (Floor Distributors) situati su ciascuno dei quattro livelli** dell'edificio.

Produrre la schematizzazione grafica

Ogni **armadio di piano rappresenta il punto di convergenza per il cablaggio orizzontale**, ovvero il tratto di rete che **raggiunge le singole postazioni di lavoro**, identificate tramite prese telematiche standardizzate (RJ45). Le direttive ingegneristiche impongono che il cavo orizzontale non superi mai la **lunghezza massima di 90 metri, a cui si sommano 10 metri concessi per i cavi di permuta** (patch cords) nei rack e nelle postazioni utente, portando il limite del canale (Channel Link) a 100 metri esatti.

Considerando la mole di dispositivi previsti - decine di host per ogni settore operativo - e la volontà di implementare reti Wi-Fi ad alta densità, si prescrive **l'utilizzo di cavi in rame a coppie intrecciate di Categoria 6A. I cavi Cat 6A supportano il protocollo 10GBASE-T**, garantendo longevità all'infrastruttura con margini di miglioramento. **L'uso di cavi schermati** mitigherà fenomeni degradanti come la diafonia esogena (Alien Crosstalk), un disturbo critico che si verifica quando fascicoli di cavi corrono paralleli all'interno delle canaline per lunghi tratti.

Architettura Logica, Modello VLAN e Topologia Finale (Progettazione architettura Logica e segmentazione)

Il cuore del ridisegno architetturale risiede nel superamento della vecchia topologia piatta e non gerarchizzata attraverso **l'introduzione delle Virtual Local Area Network (VLAN)** basate sullo standard IEEE 802.1Q. L'infrastruttura finale si presenterà come un ecosistema altamente compartimentato, distribuito sui due stabili.

Nella vecchia sede rimarranno in funzione due segmenti operativi:

1. Settore Reclami Originale, comprendente 32 host.
2. Settore Recupero Crediti Originale, comprendente 16 host.

La sede di nuova acquisizione ospiterà la porzione amministrativa dell'azienda (con tecnologia BYOD per contenere i costi, ipotizzando fino a cento utenti massimi) insieme ai server FTP precedentemente situati nel vecchio stabile, e accoglierà quattro nuovi settori operativi così composti:

1. Settore 1 (Recupero Privati): 30 host e una stampante dipartimentale.
2. Settore 2 (Recupero Aziende): 55 host e due stampanti dipartimentali.

3. Settore 3 (Reclami Privati): 12 host e una stampante dipartimentale.
4. Settore 4 (Reclami Aziende): 62 host e due stampanti dipartimentali.

La **frammentazione di oltre trecento host** in molteplici dipartimenti impone la creazione di domini **di broadcast separati**. L'utilizzo delle VLAN permette di creare reti logiche indipendenti sopra la medesima infrastruttura fisica di switch e router. Le **porte degli switch a cui sono collegati i computer degli operatori** vengono configurate in modalità **"access"** (es. switchport mode access e switchport access vlan <id>). Quando un terminale invia un pacchetto dati (frame Ethernet standard), lo switch di livello 2 inietta all'interno dell'intestazione (header) del frame un tag di 4 byte **definito dallo standard 802.1Q. Questo tag include l'identificativo univoco della VLAN (VLAN ID)**, oltre ad altre informazioni importanti per la corretta gestione.

L'incapsulamento del frame confina matematicamente e logicamente il traffico all'interno della medesima VLAN. **Un dipendente del Settore 1 non potrà mai inviare un messaggio di livello 2 a una stampante del Settore 2**, in quanto lo switch scarterà o ignorerà i pacchetti destinati a VLAN differenti qualora non vi sia un dispositivo di instradamento di livello 3 che ne autorizzi il transito.

Affinché gli switch sparsi tra i quattro piani del nuovo edificio e tra i due stabili possano propagare le informazioni di appartenenza alle VLAN, **i collegamenti fisici che interconnettono gli apparati di rete (uplink) vengono configurati in modalità "trunk"**. Le porte trunk permettono il passaggio simultaneo di pacchetti appartenenti a diverse VLAN, conservando intatto il tag 802.1Q. Allo scopo di ottimizzare la larghezza di banda e prevenire vulnerabilità di sicurezza come il VLAN Hopping, verranno configurate sulle porte di trunk solo le VLAN strettamente necessarie tramite comandi specifici (es. switchport trunk allowed vlan <vlan-list>).

In questa topologia complessa e interconnessa, la ridondanza dei collegamenti è fondamentale per scongiurare i Single Point of Failure (SPoF). Tuttavia, creare connessioni fisiche multiple tra switch inietta il rischio mortale dei loop di rete a livello 2, che provocherebbero istantanee e devastanti broadcast storm, portando la rete al collasso in pochi secondi. Tale minaccia viene **mitigata dall'esecuzione del protocollo Spanning Tree** su tutti gli switch, che pone preventivamente in stato di blocco logico le porte ridondanti, riattivandole istantaneamente solo in caso di guasto del collegamento primario.

Ingegnerizzazione dell'Indirizzamento IPv4 e Subnetting tramite VLSM (Piano di indirizzamento)

La frammentazione logica tramite VLAN richiede un piano di indirizzamento IP meticolosamente calcolato, fondato sull'assegnazione di una subnet IP distinta per ciascun dominio di broadcast. **L'utilizzo delle classi IP tradizionali, quindi classfull, comporterebbe un enorme spreco di indirizzi.**

Per ottimizzare l'allocazione all'interno dello spazio di indirizzamento privato (RFC 1918), il **progetto fa ricorso alla tecnica del Variable Length Subnet Masking (VLSM)**. Il VLSM consente di suddividere iterativamente uno spazio di rete in sottoreti di dimensioni diseguali, adattando la maschera di sottorete (Subnet Mask) al numero effettivo di host necessari per ogni specifico dipartimento.

Ipotizzando come rete di partenza lo spazio privato 172.16.0.0/16, si procede all'allocazione

partendo dalle reti più popolate verso quelle con un numero inferiore di host, in modo tale da limitare al massimo gli sprechi nello spazio di indirizzamento ed evitare eventuali errori di calcolo.

Il calcolo si basa sulla formula $2^h - 2 \geq N$, dove h rappresenta i bit dedicati agli host (impostati a 0 nella Subnet Mask binaria), il '-2' sottrae l'indirizzo di rete e l'indirizzo di broadcast inservibili per gli end-point, ed N corrisponde alla quantità di dispositivi totali da indirizzare.

La mappatura delle sottoreti per l'infrastruttura multi-edificio è riepilogata nella seguente tabella:

Localizzazione e Dipartimento	VLAN ID	IP Operativi (Host + Print + GW)	Bit di Host (h)	Subnet/ CIDR	Net Address	Range (Primo - Ultimo)	Broadcast
Nuovo Edificio - Amministrazione (BYOD)	50	Max 100 utenti + 1 Gateway = 101	7 bit (126 host)	255.255.255.128 (/25)	172.16.1.0	172.16.1.1 - 172.16.1.126	172.16.1.127
Nuovo Edificio - Settore 4 (Reclami Aziende)	40	62 host + 2 stampanti + 1 GW = 65	7 bit (126 host)	255.255.255.128 (/25)	172.16.1.128	172.16.1.129 - 172.16.1.254	172.16.1.255
Nuovo Edificio - Settore 2 (Recupero Aziende)	20	55 host + 2 stampanti + 1 GW = 58	6 bit (62 host)	255.255.255.192 (/26)	172.16.2.0	172.16.2.1 - 172.16.2.62	172.16.2.63
Vecchio Edificio - Reclami Originale	70	32 host + 1 GW = 33	6 bit (62 host)	255.255.255.192 (/26)	172.16.2.64	172.16.2.65 - 172.16.2.126	172.16.2.127
Nuovo Edificio - Settore 1 (Recupero Privati)	10	30 host + 1 stampante + 1 GW = 32	6 bit (62 host)	255.255.255.192 (/26)	172.16.2.128	172.16.2.129 - 172.16.2.190	172.16.2.191
Vecchio Edificio - Recupero Originale	60	16 host + 1 GW = 17	5 bit (30 host)	255.255.255.224 (/27)	172.16.3.0	172.16.3.1 - 172.16.3.30	172.16.3.31
Nuovo Edificio - Settore 3 (Reclami Privati)	30	12 host + 1 stampante + 1 GW = 14	4 bit (14 host)	255.255.255.240 (/28)	172.16.3.32	172.16.3.33 - 172.16.3.46	172.16.3.47
Server Farm (FTP Recupero, FTP Reclami, DHCP)	80	3 Server + 1 GW = 4	3 bit (6 host)	255.255.255.248 (/29)	172.16.3.48	172.16.3.49 - 172.16.3.54	172.16.3.55
Area Demilitarizzata (DMZ - Server Web)	90	1 Server + 1 GW = 2	2 bit (2 host)	255.255.255.252 (/30)	172.16.3.56	172.16.3.57 - 172.16.3.58	172.16.3.59

La metodologia **VLSM illustrata garantisce un uso parsimonioso dello spazio di rete**. A titolo esplicativo, per il Settore 3 (Reclami Privati) che necessita di soli 14 indirizzi operativi, la maschera a 28 bit (255.255.255.240) limita matematicamente lo spazio disponibile a 16 indirizzi totali (incluso rete e broadcast), evitando l'allocazione inutile di interi blocchi da 256 indirizzi tipici dell'indirizzamento classful. Oltre a garantire ordine logico, **l'allocazione contigua degli indirizzi consente ai router di effettuare processi di Route Summarization**, ovvero di raggruppare intere serie di reti in un'unica stringa tabellare, alleggerendo drasticamente il carico sui processori di instradamento aziendali. Tutti i terminali dei settori operativi verranno configurati con IP statici (manuali) per garantire un ferreo controllo sulle macchine aziendali autorizzate, ad eccezione dell'area amministrativa che sfrutterà l'assegnazione dinamica per via del BYOD.

Instradamento Inter-VLAN e Protocolli di Tolleranza ai Guasti (Layer 3) (Gestione delle reti segmentate)

Il confinamento operato al livello di Data Link dalle VLAN rende impossibile a due computer appartenenti a dipartimenti diversi di dialogare. Poiché il testo impone che le stazioni operative debbano accedere ai Server FTP allocati nella Server Farm (VLAN 80), l'intervento di dispositivi che operano a Livello 3 (Router o Multilayer Switch) si rende assolutamente necessario per poterli fare comunicare.

La tecnica impiegata per far dialogare queste entità separate prende il nome di Inter-VLAN routing. Nelle architetture classiche, si farebbe ricorso alla topologia "Router on a stick", la quale ottimizza l'hardware a disposizione creando interfacce virtuali (sub-interfaces) su una singola interfaccia fisica di un router (ad esempio GigabitEthernet0/0). Tramite la riga di comando (CLI), l'amministratore attiva l'incapsulamento del frame per ogni sub-interface (es. encapsulation dot1q 10 per il Settore 1) assegnandole l'indirizzo IP del Default Gateway calcolato precedentemente nel piano VLSM.

Questa interfaccia fisica viene interconnessa al core switch mediante un collegamento trunk. I frame generati da un PC giungono allo switch locale, vengono taggati, transitano per le dorsali fino allo switch centrale e risalgono il cavo verso il router. Qui, il pacchetto viene privato del tag (decapsulato), il router ispeziona l'indirizzo IP di destinazione (Livello 3), ricalcola il percorso, aggiunge il tag della VLAN di destinazione e inoltra nuovamente il pacchetto lungo lo stesso cavo

verso lo switch, che provvederà al recapito finale.

Schematizzare il funzionamento del Router on a stick

In ambienti ad altissima densità come il nuovo scenario multi-edificio, questa operazione viene preferibilmente gestita a velocità di bus interno hardware (wire-speed) mediante l'utilizzo di Switch Layer 3 (Multilayer Switch), i quali configurano le interfacce virtuali (SVI - Switch Virtual Interface) operando con prestazioni di gran lunga superiori rispetto a un router tradizionale. (Questa è un'ottima soluzione che consente di utilizzare soli switch layer3 piuttosto che la combinazione router+switches)

L'instradamento non si limita alla topologia locale, ma si estende ai nodi geografici. La comunicazione tra l'edificio vecchio e quello nuovo esige l'elaborazione di tabelle di routing dinamiche o statiche. L'algoritmo decisionale del router determina il percorso migliore analizzando metriche di costo. Nelle connessioni tra macro-nodi si applicano protocolli di routing dinamico Link-State, come OSPF (Open Shortest Path First). **L'OSPF sfrutta l'algoritmo matematico Shortest Path First (SPF) di Dijkstra per creare una mappa topologica completa della rete(protocollo link state), consentendo al router di adattarsi in frazioni di secondo alla caduta di un link primario, al contrario di ciò che succede ai protocolli distance vector meno onerosi in termini di risorse ma più lenti a convergere in caso di guasti.**

Per rafforzare la resilienza dell'infrastruttura contro scenari catastrofici (disaster recovery), si progetta una ridondanza multilivello. A livello di routing statico, qualora si disponesse di linee secondarie anche a banda ridotta **si implementerebbero le "Floating Static Routes"(ripassatee!!).**

Una rotta fluttuante viene iniettata nella configurazione globale (es. ip route <rete_destinazione> <mask> <interfaccia> 5) specificando una Distanza Amministrativa (AD) superiore rispetto al protocollo in uso. Essendo meno "affidabile" per il router (ad esempio AD=5 contro l'AD=1 di una statica classica o AD=110 dell'OSPF), la rotta rimane invisibile(non visibile in routing table ma presente in running config), subentrando istantaneamente nei processi di instradamento solo qualora l'interfaccia primaria si interrompa inaspettatamente.

A livello di Gateway locale, la ridondanza è assicurata da protocolli FHRP (First Hop Redundancy Protocol) come l'HSRP (Hot Standby Router Protocol). In HSRP, due router fisici si accordano per condividere un indirizzo IP virtuale e un MAC Address virtuale; il ruolo di gestore del traffico (Active) spetta a un router, mentre l'altro resta in ascolto (Standby). Qualora l'hardware del router attivo dovesse collassare, lo Standby assume il controllo del Gateway in pochi millisecondi, rendendo l'avaria completamente trasparente per i 300 dipendenti al lavoro.

Implementazione delle Access Control List (ACL) e Sicurezza Perimetrale (Architettura di sicurezza: aaa, dmz e filtraggio)

Il cuore della sicurezza logica interna dell'azienda è dettato da stringenti direttive amministrative e legali. I dati relativi a reclami e procedure di recupero crediti rivestono carattere di estrema confidenzialità. Il mandato progettuale stabilisce, senza ambiguità, che i vari settori, curando aspetti operativi differenti, devono permanere logicamente indipendenti l'uno dall'altro.

Inoltre, si impone che "le stampanti sono ad uso esclusivo di ogni settore e non devono poter essere raggiunte da settori diversi". Parallelamente, è normato l'accesso ai file server centrali: il

Settore 1 e 2 (Recupero) accedono unicamente al server FTP-Recupero; il Settore 3 e 4 (Reclami) accedono unicamente al server FTP-Reclami, mentre l'Amministrazione gode di privilegi di accesso totale su ambedue i sistemi.

Tali direttive amministrative si traducono tecnicamente nella programmazione delle Access Control List (ACL) all'interno dei dispositivi di instradamento. **Un'ACL funge da sistema di filtraggio dei pacchetti** (packet filtering firewall), operando ispezioni ai livelli 3 (Rete - indirizzi IP) e 4 (Trasporto - porte TCP/UDP) della pila OSI.

Si **esclude a priori l'utilizzo di ACL di tipo "Standard"**, poiché la loro architettura permette di filtrare i pacchetti esaminando unicamente l'indirizzo IP di origine, obbligando i sistemisti a **posizionarle il più vicino possibile alla destinazione**, con evidenti limiti relativi alla granularità della soluzione che si intende prospettare. Oltretutto, una tale implementazione comporterebbe uno spreco di banda enorme, in quanto il traffico vietato viaggierebbe attraverso l'intera infrastruttura per poi essere scartato a un passo dalla meta, dato che l'eventuale "deny" andrebbe ad applicarsi vicino alla destinazione, dopo che il pacchetto ha viaggiato da mittente a destinatario. Al contrario, si adoperano le ACL Estese (Extended ACL), le quali ispezionano simultaneamente l'indirizzo sorgente, l'indirizzo di destinazione e lo specifico protocollo di livello di trasporto. Le best-practice ingegneristiche impongono di posizionare le **ACL estese il più vicino possibile all'origine** del traffico, bloccando alla radice (in ingresso sull'interfaccia - inbound) la propagazione dei pacchetti illeciti o non autorizzati.

L'implementazione per il "Settore 1 - Recupero Privati", ad esempio, risponderà alla seguente logica procedurale sulla sub-interface di afferenza:

1. **Permesso al Server FTP dedicato:** Verrà creata una direttiva
permit tcp <ip_sorgente> <wildcard_mask> host <ip_server_ftp_recupero> eq 21

L'ispezione sulla porta 21 (FTP Control) e sulle porte effimere autorizzerà unicamente i client di questo settore ad instaurare la connessione orientata alla connessione (3-way handshake) verso il file server corretto.

2. **Negazione verso gli altri Server:** Una direttiva
deny ip <ip_sorgente> <wildcard_mask> host <ip_server_ftp_reclami>

Renderà impossibile per il Settore 1 tentare di intrufolarsi nei documenti dell'ufficio reclami.

3. **Protezione delle Stampanti e degli altri Settori:** Un blocco
deny ip <ip_sorgente> <wildcard_mask> <ip_rete_destinazione> <wildcard_mask>

Verrà replicato per isolare il traffico da tutti gli altri dipartimenti, bloccando non solo la condivisione illecita di file via SMB o query ICMP, ma schermando fisicamente le stampanti dipartimentali da tentativi di stampa non autorizzati.

Fondamentale nel calcolo delle direttive è la gestione **dell'Implicit Deny (negazione implicita)**. Ogni ACL, per design, conclude la sua lista di istruzioni con un blocco invisibile che scarta tutto il traffico non espressamente consentito in precedenza. Omettere il comando risolutivo permit ip any any equivarrebbe a tranciare l'accesso dei dispositivi aziendali verso reti legittime (come la navigazione internet per il reparto amministrativo).

Ciononostante, nelle policy rigorose della nostra azienda, il traffico inter-dipartimentale verrà

scartato dal deny implicito o reso esplicito tramite regole per generare log utili ai firewall aziendali, consentendo agli analisti della sicurezza di rintracciare in tempo reale tentativi di esfiltrazione dati o la proliferazione di malware autoreplicanti.

Evoluzione della Sicurezza ai Livelli Superiori: IDS, IPS e DPI

Sebbene **le ACL e i tradizionali firewall** di instradamento forniscano un robusto livello di isolamento ai livelli di Rete e Trasporto, essi **risultano di fatto "ciechi" rispetto all'effettivo contenuto (payload)** dei pacchetti. Un attaccante (sia esso un intruso esterno o una minaccia "insider") **potrebbe sfruttare** una porta legittimamente consentita, **ad esempio la porta TCP 21 dell'FTP**, per veicolare malware o lanciare exploit applicativi contro la server farm. Per colmare questa limitazione tecnologica e proteggere i dati sensibili dell'impresa in modo proattivo, la rete moderna richiede l'integrazione di sistemi avanzati come gli Intrusion Detection System (IDS) e Intrusion Prevention System (IPS).

L'**IDS** opera come un sistema passivo di "ascolto": posizionato tramite sonde (sensori) nei **punti nevralgici della rete, analizza costantemente il traffico** duplicato confrontandolo con un **database di signature** (o di fingerprint) (firme virali e pattern di attacchi noti) o rilevando anomalie comportamentali. Nel caso in cui venga **rilevata una criticità** o un accesso non autorizzato ai sistemi FTP, **l'IDS non interrompe il traffico**, ma **genera un avviso** (alert) e compila i file di log, segnalando tempestivamente l'anomalia agli amministratori di rete. A differenza del firewall, che si trova fisicamente sul percorso obbligato dei pacchetti (in linea), l'IDS viene posizionato a lato della rete, spesso collegato a una porta speciale dello switch chiamata Porta Mirror, avendo quindi il vantaggio di ricevere solo una *copia* del traffico, se l'IDS si guasta la rete continua a funzionare normalmente ma lo svantaggio è quello di non poter intervenire fisicamente per bloccare l'attacco, potendo solo lanciare l'allarme.

Per difendersi attivamente e bloccare i malware prima che si diffondano, all'IDS viene affiancato l'**IPS** (Intrusion Prevention System). **Posto tipicamente in-line** (cioè direttamente sul percorso fisico o logico dei dati, solitamente integrato nei Next-Generation Firewall), l'IPS lavora in tempo reale. A **differenza di un'ACL che blocca basandosi su indirizzi IP, l'IPS agisce specificamente su programmi** e utenti; se intercetta un attacco o un tentativo di exploit all'interno di un flusso dati apparentemente lecito, **provvede a "droppare"** (scartare) i pacchetti incriminati e a chiudere immediatamente la connessione.

Tuttavia, queste ispezioni richiedono una capacità di analisi che oltrepassa l'header IP/TCP. Affinché un IPS o un Next-Generation Firewall sia veramente efficace nell'identificare le minacce moderne, esso deve sfruttare la **tecnologia DPI (Deep Packet Inspection)**. Il DPI permette di superare i limiti storici della rete end-to-end **"spacchettando" l'informazione fino al Livello 7** (Applicativo) del modello OSI. Tramite l'ispezione profonda dei pacchetti, l'apparato di rete è in grado di **leggere l'esatta natura dei dati veicolati** e bloccare, ad esempio, un file eseguibile nascosto o richieste applicative anomale che transitano attraverso porte consentite, azzerando virtualmente il rischio per il settore recupero crediti aziendale. Tuttavia, la DPI richiede un'enorme potenza di calcolo, rallenta il traffico e solleva enormi problemi di Privacy (specialmente con il traffico cifrato HTTPS), dato che, per poter leggere il contenuto del payload a volte è necessario operare dei veri e propri attacchi MitM.

L'Infrastruttura DHCP per il Paradigma (BYOD

definizione dei servizi di rete)

L'integrazione del concetto Bring Your Own Device (BYOD) costituisce un perno strategico del trasferimento amministrativo nel nuovo stabile. L'azienda intende abbattere i costi operativi (Le gestione dei PC interni alla azienda) consentendo ai dipendenti dirigenziali e amministrativi di operare utilizzando i propri laptop e dispositivi mobili. A differenza delle macchine fisse dei settori operativi, che richiedono l'imposizione di IP statici per scopi di tracciamento forense e blindatura delle ACL, i **dispositivi degli utenti BYOD hanno carattere transitorio** e necessitano di configurazioni di rete agili ed erogate in maniera trasparente e automatizzata.

Il servizio prescelto per tale operazione è il DHCP (Dynamic Host Configuration Protocol), un protocollo di livello applicativo (Livello 7 OSI) operante su datagrammi UDP. Il ciclo di assegnazione segue la rigorosa sequenza DORA (Discover, Offer, Request, Acknowledge). Quando il laptop di un dirigente BYOD si collega alla VLAN 50, esso emette in broadcast (indirizzo destinazione IP 255.255.255.255 e MAC FF:FF:FF:FF:FF:FF) un pacchetto di DHCP Discover alla ricerca di un server capace di fornirgli i parametri di rete.

La topologia di rete, per evidenti ragioni architettureali e di sicurezza, pone il Server DHCP fisico in una subnet remota, protetta all'interno della Server Farm (VLAN 80), isolata dai client. I router, per definizione costituzionale di Livello 3, bloccano le trasmissioni broadcast al confine dell'interfaccia per evitare congestioni che si propagano attraverso le reti. Questo provocherebbe il fallimento sistematico della sequenza DORA e pertanto del DHCP. La soluzione ingegneristica risiede nell'attivazione della funzione di **DHCP Relay**. Sull'interfaccia virtuale che funge da Gateway per il settore amministrativo (VLAN 50), l'amministratore imposterà il comando ip helper-address <Indirizzo_IP_Server_DHCP>. Questa direttiva istruisce l'interfaccia a intercettare i messaggi UDP sulla porta 67 provenienti dal laptop BYOD e a reencapsularli in pacchetti unicast indirizzati direttamente alla macchina Server DHCP situata nella Server Farm, abbattendo le barriere di segmentazione.

La traccia richiede esplicitamente che il servizio DHCP sia dimensionato in modo tale da "indirizzare al massimo cento utenti" BYOD. Il pool IP associato all'amministrazione (172.16.1.0/25) possiede teoricamente 126 indirizzi IP utili. Per rispondere in maniera chirurgica al requisito imposto, si utilizzerà la funzione di esclusione degli indirizzi (excluded-address). All'interno del server DHCP, i sistemisti escluderanno dal meccanismo di allocazione dinamica i primi indirizzi (ad esempio da 172.16.1.1 a 172.16.1.15, riservati per default gateway, access point futuri, switch di piano) e gli ultimi 11 indirizzi (da 172.16.1.116 a 172.16.1.126). Il pool dinamico risultante sarà confinato esattamente a 100 lease temporanei.

In caso di anomalia temporanea del server DHCP - per indisponibilità hardware o blocco dei tunnel inter-VLAN - i dispositivi BYOD sfrutterebbero il **protocollo APIPA (Automatic Private IP Addressing)**. Con questa tecnologia di fallback, attivata di default sui sistemi operativi client, il computer si autoconfigurerebbe un indirizzo IP pseudocasuale nell'intervallo 169.254.0.0/16 (con subnet mask 255.255.0.0). Pur non permettendo di superare i confini del router (gateway 0.0.0.0), questa assegnazione di emergenza segnalerebbe immediatamente al reparto IT la caduta dei servizi DHCP.

Connettività Remota e Virtual Private Network

Il mondo aziendale moderno è soggetto a imprevedibili eventi esogeni in grado di paralizzare la mobilità dei dipendenti, come ampiamente dimostrato dall'emergenza pandemica del Covid-19 citata nella problematica in esame o una eventuale ed attuale crisi energetica (In questi giorni viene persino paventata l'idea di ricorrere alla cosiddetta DaD per le fasi finali dell'a.s.). Diventa perciò tassativo sviluppare un'infrastruttura capace di garantire la Business Continuity, estendendo il perimetro logico della LAN aziendale fino alle abitazioni private dei lavoratori operativi e amministrativi. La direttiva chiede esplicitamente di consentire l'accesso "alla rete locale di propria competenza ed ai relativi server FTP dall'esterno".

L'esposizione diretta dei server FTP privati verso l'Internet pubblico costituirebbe una violazione imperdonabile dei protocolli di sicurezza. L'informazione transiterebbe su mezzi trasmissivi aperti, soggetta a facile intercettazione (sniffing), e i server stessi diverrebbero un bersaglio stazionario per attacchi di tipo forza bruta e Denial of Service (DoS). La soluzione ingegneristica per risolvere tale dicotomia consiste nell'implementazione di una Virtual Private Network (VPN) per l'accesso remoto (Remote Access VPN).

Una rete VPN non è un cavo fisico, bensì un "tunnel virtuale" logico costruito crittograficamente al di sopra dell'infrastruttura di Internet. Per la fattispecie dei computer privati o BYOD, la tecnologia d'elezione non ricade sul protocollo IPsec, che necessiterebbe di software client ingombranti e ampi privilegi amministrativi sul lato macchina utente, ma sulle VPN Secure Socket Layer / Transport Layer Security (SSL/TLS VPN). Questa famiglia di reti virtuali opera a livello di Applicazione/Trasporto, garantendo una fluidità estrema; i dipendenti potranno autenticarsi e accedere ai depositi aziendali sfruttando spesso nient'altro che un browser web aggiornato.

L'architettura della SSL VPN offre tre gradi di garanzia crittografica inattaccabili ¹:

1. **Riservatezza (Confidentiality):** La conversazione tra il PC dell'utente in isolamento domestico e il concentratore VPN situato sui confini dell'azienda (Router Edge) è schermata da algoritmi di cifratura simmetrica fortissimi, come l'Advanced Encryption Standard (AES) a 256 bit. Ogni pacchetto contenente i dati sensibili di un debito o di un reclamo risulta illeggibile ai fornitori di accesso (ISP) e ai cyber-criminali.
2. **Integrità (Integrity):** Sofistiche funzioni di hash crittografico (es. SHA-256 o SHA-384) appongono un sigillo digitale ai pacchetti (Message Authentication Code), assicurando matematicamente che l'informazione inviata dal server giunga intatta al computer del dipendente, prevenendo manipolazioni in itinere.
3. **Autenticazione Estesa (Authentication):** Le connessioni instaurate vengono sottoposte a validazioni identitarie granulari. Integrando un server AAA (Authentication, Authorization, Accounting) basato su protocollo RADIUS, non solo si verifica la password del dipendente, ma si innesca la multi-fattorialità (MFA) tramite smartphone (Applicativi per l'autenticazione tramite token), associando il profilo utente alla sua esatta qualifica.

L'associazione di quest'ultima caratteristica si lega indissolubilmente al requisito di separazione richiesto. Al momento del login al portale VPN, il server riconoscerà, ad esempio, le credenziali di un operatore del "Settore 1". Attraverso l'uso di ACL Dinamiche scaricate contestualmente all'autenticazione, il tunnel del dipendente riceverà solo e unicamente i diritti per incanalare il traffico (Split Tunneling) verso lo specifico IP del Server FTP-Recupero, mantenendo cieco e inaccessibile il server dei reclami o i domini di stampa interna. Questa commistione tra crittografia simmetrica e instradamento filtrato crea una gabbia protettiva perfetta per il lavoro agile a distanza. In particolare le ACL Dinamiche vengono gestite dal server AAA come ad esempio

RADIUS, che una volta certificata la triple A verifica se per la sessione sono applicabili delle particolari regole su come va gestito il traffico, in quel caso RADIUS comunica al router la particolare ACL da applicare alla sessione.

Pubblicazione Web Esterna e Progettazione della DeMilitarized Zone (DMZ)

Oltre al personale interno, la traccia solleva la volontà aziendale di proiettare i propri servizi verso la clientela finale, offrendo "un servizio web che consenta alle persone esterne... di conoscere lo stato della propria pratica/reclamo". Questo requisito introduce un vettore di rischio esterno altissimo. Per mettere **un server in ascolto su Internet** affinché riceva le richieste HTTP/HTTPS del pubblico, è **inaccettabile posizionarlo all'interno della rete locale (LAN)**, poiché la compromissione di tale macchina - ad esempio tramite un exploit di livello applicativo o vulnerabilità zero-day del server web Apache/Nginx - offrirebbe agli hacker un "piede di porco" per dilagare orizzontalmente all'interno delle VLAN aziendali e depredare i server FTP critici.

La protezione sistematica di questa infrastruttura impone la realizzazione di **un'architettura DMZ** (DeMilitarized Zone). La DMZ è una vera e propria "terra di mezzo", una rete fisicamente e logicamente distinta (nel nostro schema assegnata alla VLAN 90), isolata tra la rete pubblica e l'ambiente altamente fidato interno. Il Web Server risiederà su questa subnet "cuscinetto".

Le regole che governano il firewall di perimetro orchestrano i permessi in maniera asimmetrica. L'accesso dall'esterno, proveniente dal traffico WAN indifferenziato (Clienti), sarà permesso e vincolato esclusivamente all'indirizzo IP pubblico associato al Server Web. Ma la regola cardinale della DMZ stabilisce che tutto il traffico generato intrinsecamente dalla DMZ verso la LAN interna aziendale sia bloccato senza eccezioni (Deny). Di conseguenza, un attaccante che prendesse possesso del server non potrebbe comunque stabilire connessioni verso i database della rete locale. Per alimentare il server web con lo stato aggiornato delle pratiche dei clienti, la comunicazione dovrà avvenire in senso inverso: saranno i server interni protetti della LAN a farsi promotori di sincronizzazioni asincrone inviando (push) copie strutturate dei database verso la DMZ a intervalli regolari.

A livello di indirizzamento, il **Server Web all'interno** della DMZ sfrutterà un **IP privato non routabile** su Internet. Affinché i **browser di un cliente possano interrogarlo, il router perimetrale applicherà** il protocollo NAT in formato Statico (Network Address Translation Statico o Port Forwarding). L'amministratore configurerà una traslazione (es. ip nat inside source static tcp 172.16.3.57 443 <IP_Pubblico> 443), mappando univocamente l'IP mondiale fornito dal Service Provider sull'interfaccia privata del Server. Contemporaneamente definirà il confine delle interfacce con le istruzioni ip nat outside sul ramo rivolto al provider internet e ip nat inside per la porta rivolta alla DMZ (**Puoi anche schematizzare l'applicazione di queste regole**).

L'accesso a queste informazioni debitorie non può in alcun modo essere gestito in chiaro tramite il protocollo HTTP nativo (porta TCP 80), in quanto i pacchetti scambiati subirebbero una letale intercettazione ai nodi intermedi di internet, portando a gravissime sanzioni per violazioni della privacy. La crittografia delle transazioni web è demandata alla suite HTTPS (Hypertext Transfer Protocol Secure) che lavora in abbinata al layer TLS. **In aggiunta alla cifratura simmetrica, la connessione è anticipata da un Handshake Asimmetrico: il Web Server esibisce al client del cittadino un Certificato Digitale X.509 validato da una Certification Authority (CA) terza. L'utente**

ha l'assoluta certezza di interagire con il dominio reale dell'azienda, vanificando sul nascere frodi informatiche e attacchi Man-in-the-Middle (MitM) basati sul DNS Spoofing.

Infrastruttura Wireless BYOD e Controllo degli Accessi (IEEE 802.1X)

A completamento della transizione tecnologica per il settore amministrativo, si esamina lo svincolo dalla rigidità del cablaggio in rame. I Laptop dirigenziali, spesso sprovvisti fisicamente della tradizionale interfaccia RJ45 e dotati di sole porte Wi-Fi, impongono l'irradiazione di una copertura Wireless Local Area Network (WLAN).

L'infrastruttura Wi-Fi per la palazzina si realizza disseminando punti di accesso (Access Point) sui soffitti dei piani amministrativi. Per garantire un'amministrazione oculata e roaming senza interruzioni di segnale (seamless roaming) durante gli spostamenti degli utenti, si evita l'impiego di Access Point autonomi. Vengono invece schierati Access Point di tipo "Lightweight" (LAP), controllati cerebralmente da un Wireless LAN Controller (WLC) posizionato nei rack del centro stella.

La porta fisica dello switch su cui il traffico del WLC sbarca è associata nativamente e saldamente in modalità access alla VLAN 50 dell'Amministrazione. Il WLC trasmette nell'etere il Service Set Identifier (SSID), ad esempio denominato "WifiAmm". Tuttavia, a differenza del cavo di rete le cui prese murarie sono circonscritte da pareti chiuse e sorvegliate a vista, le onde radio del Wi-Fi sorpassano i confini murari dell'azienda divenendo intercettabili dai parcheggi o dalla strada. Questo rende le vulnerabilità in ambito wireless profondamente asimmetriche rispetto alla LAN cablata.

L'uso di metodologie di sicurezza basate su password pre-condivise (come il WPA2-Personal/PSK) rappresenta una criticità insormontabile. La condivisione massiva di una password tra decine di impiegati o peggio, l'immissione nei loro terminali BYOD personali, garantisce la perdita pressoché immediata del segreto, con conseguente impossibilità tecnica per gli analisti IT di tracciare le transazioni al singolo utente. Le falle di questo sistema impongono un salto di paradigma verso l'architettura AAA (Authentication, Authorization, and Accounting).

Per soddisfare l'imperativo della messa in opera sicura, il progetto integra lo standard IEEE 802.1X (Port-Based Network Access Control) coniugandolo con lo standard WPA3-Enterprise per l'encryption aerea dei frame operati sulle modulazioni di frequenza. Il protocollo 802.1X si basa su una rigida tripartizione logica dei ruoli di rete:

1. Il **Supplicant**: Il software presente nel tablet o laptop del dirigente che tenta la connessione SSID.
2. L'**Authenticator**: L'Access Point (veicolato dal WLC) che funge da guardiano per il cancello logico di ingresso e intercetta le richieste dell'utente.
3. L'**Authentication Server**: Il server di sicurezza centrale, che opera con protocolli come RADIUS, spesso interfacciato direttamente ai database di dominio aziendali come l'Active Directory.

In fase di aggancio allo SSID "WifiAmm", la porta virtuale di ingresso per l'utente è serrata, incapace di trasmettere traffico IP, eccezion fatta per specifici messaggi di autenticazione EAP (Extensible Authentication Protocol) incapsulati in LAN (EAPoL) per essere propagati nella rete. Il

Supplicant richiede il login all'utente non con una chiave generica di rete, ma con le credenziali individuali (Username, Password personale) arricchite potenzialmente con certificati digitali (EAP-TLS). L'Authenticator rilancia il segreto all'Authentication Server per mezzo di tunnel sicuri RADIUS. Solo ed esclusivamente in caso di "Success" proveniente dal database centrale (accertata identità del dirigente), l'Authenticator apre la porta virtuale in modalità di forwarding, consentendo il transito IP e avviando la sequenza DORA di DHCP esaminata in precedenza.

Possibili schematizzare

Questa architettura sigilla la vulnerabilità cardine del BYOD: se il dirigente termina la sua collaborazione lavorativa, la cancellazione della sua sola utenza sul server RADIUS disabilita permanentemente l'accesso ai depositi FTP, precludendo l'immissione ai terminali che rimangono di sua proprietà e preservando il patrimonio informatico societario da fughe logiche. Oltretutto, ogni trasmissione su portante radio da e verso il suo terminale beneficia di chiavi crittografiche monouso derivate specificatamente per l'utente al termine dell'handshake (PMK), escludendo del tutto che altri dipendenti collegati alla medesima frequenza radio possano sniffare o decifrare il traffico reciproco (mitigato ulteriormente da policy di "Client Isolation" applicate dal WLC).

Considerazioni di sintesi finali

In conclusione, la disamina estensiva delle limitazioni di natura broadcast che affliggevano la rete primordiale e la contestualizzazione delle nuove normative imposte dall'aumento volumetrico delle macchine ha permesso la modellazione matematica e fisica di un impianto refrattario agli attacchi interni o a cadute sistemiche. Le tecnologie di cablaggio in fibra, l'uso massivo dell'isolamento a layer 2 tramite l'802.1Q e la parsimoniosa gestione tabellare mediante VLSM garantiscono una fondazione stabile e un'invidiabile ottimizzazione delle risorse inistradabili.

I server di frontiera(Web Server) e periferici FTP, cruciali ai fini della prosecuzione dell'impresa di recupero crediti, rifulgono protetti dalle barriere delle Access Control List estese e dall'implementazione rigida dei percorsi dedicati ai settori autorizzati (). Infine, la flessibilità organizzativa garantita dalla messa a regime di reti Wireless 802.1X, del provisioning calibrato tramite helper DHCP, dei portali di DeMilitarized Zone nati asimmetricamente per il feedback al cliente e delle connessioni virtuali criptate SSL, ha trascorso la fisicità del cablaggio , consegnando alla direzione tecnica un sistema resiliente, tracciabile, performante in tutte le sue espansioni future, e massimamente rispettoso della natura critica dei dati trattati.

I quesiti di seconda parte sono a sviluppo prettamente teorico per cui non sono parte di questo sviluppo esemplificativo